Security Assessment

OWASP Top 10 2021, API Security Top 10 2023, ASVS 4.0 L2 | CVSS v3.1 | Run date 2026-11-02 (run 5, full re-execution from an empty sandbox). Static checks (npm ci, audit, lint, build, Semgrep, secret scan) ran on main HEAD df46295; main HEAD does not build, so behavioural tests (HTTP, browser, axe, ZAP) ran on 1c85d7d, the last buildable commit (the HEAD moved during the run: 14 commits, 23 files). Tools: node 22.23.4, npm 10.9.9, next 14.2.5 (installed), semgrep 1.183.0, OWASP ZAP 2.16.1 (java 21), playwright-core 1.56.1 (pinned), axe-core 4.10.2 (pinned), curl 8.5.0, reportlab 5.0.1.

1. Executive summary

18 findings: 0 critical, 4 high, 10 medium, 4 low, 0 info (severity is derived only from the CVSS v3.1 base score). Run 4 had 18 findings (1 critical, 3 high, 9 medium, 4 low, 1 info); the scores are recalculated from the vectors in this report, and two findings are new (S-08 AI search, S-09 list-your-property). Production is still not deployed on Catalyst (Production Slate deployment status = failed since 2026-10-14, verified this run), so the exposure below is for the code on main and the Development environment, not a live Production site.

New blocker on main: commit df46295 ('UPDATES', pushed 2026-11-02 during this run) added about 5,900 lines to src/app/list-your-property/page.js (now 7,952 lines, several pasted copies), which declares getRecordName twice. **next build fails and lint reports a parsing error on main HEAD**, so nothing deployable can be produced. The last buildable commit in this run was 1c85d7d (build and lint passed). Behavioural security tests therefore describe 1c85d7d; static checks describe HEAD.

Resolved since run 4 (verified this run): npm ci now succeeds (lockfile in sync); Data Store row count matches CRM (177 = 177); on 1c85d7d build and lint passed (not on HEAD). **Worse:** Next.js is pinned to 14.2.5, so npm audit rose from 13 to 19 vulnerabilities.

Top actions: (1) stop returning every Data Store column, including SPOC phone numbers (S-05); (2) harden or retire /api/lead2, /api/lead3 and the duplicate-overwrite path (S-02, S-03, S-04); (3) rate-limit and cap /api/ai-search before launch (S-08); (4) upgrade Next.js to 14.2.35 or later (S-01); (5) add security headers (S-07); (6) fix Catalyst settings: public sign-up, App User write, bucket encryption (S-10).

2. Findings register

ID / status	Sev / CVSS	Finding	OWASP 2021 / API 2023 / ASVS	CWE	How verified	Recommendation
S-04 Persisting	**High** 8.2 AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:N	Duplicate-lead handling lets an anonymous caller update an existing CRM lead (PUT /crm/v8/Leads/{id}, workflows triggered) with attacker-supplied values and reveals that the phone/email already exists.	A01:2021 Broken Access Control API1:2023 Broken Object Level Authorization ASVS V4.2.1	CWE-639, CWE-285, CWE-200	Code read of leads/route.js duplicate path (updateData built from request, PUT with trigger workflow). Not executed (would write to production CRM).	On duplicates append a note/activity instead of overwriting fields; return a generic success response.
S-01 Persisting (worse)	**High** 7.5 AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H	Next.js is pinned to the exact version 14.2.5 in package.json (run 4 resolved 14.2.35). npm audit now reports 19 vulnerabilities (1 critical, 14 high, 4 moderate); 37 Next.js advisories apply, including DoS in Server Components and image optimizer, cache poisoning and SSRF. The critical advisory (middleware authorization bypass, fixed 14.2.25) is not reachable because the repo has no middleware file; the DoS advisories are reachable.	A06:2021 Vulnerable and Outdated Components API8:2023 Security Misconfiguration ASVS V14.2.1	CWE-1104, CWE-937	Executed: npm ci then npm audit (02b_npm_audit.log, npm_audit.json); next/package.json version read; git ls-files shows no middleware.	Upgrade to next 14.2.35 or later within the 14.x line (npm reports a non-major fix) and drop the exact pin; then move to a supported major.
S-02 Persisting	**High** 7.5 AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N	/api/lead2 (home-page requirement form) has no rate limit, no content-type or body-size check, no honeypot and no phone/email validation, and writes client-supplied leadSource, leadStatus and subLeadSource to CRM Leads.	A04:2021 Insecure Design API4:2023 Unrestricted Resource Consumption ASVS V13.2.1, V5.1.3	CWE-20, CWE-915, CWE-770	Code read of lead2/route.js (no validators present; Lead_Source taken from body) and API test (08_api_tests.log, RATE lead2 burst: no 429). End-to-end write not executed (production CRM writes forbidden).	Retire lead2/lead3 or give them the same validation, honeypot, size and rate limit as /api/leads; whitelist Lead_Source/Status server-side.

ID / status	Sev / CVSS	Finding	OWASP 2021 / API 2023 / ASVS	CWE	How verified	Recommendation
S-05 Persisting	**High** 7.5 AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N	The public property API returns every Data Store column. propertyMapper spreads ...row with no allow-list, so SPOCName, SPOCNumber, QuotedRent, AchievableRent and crmID are public. Catalyst query this run: SPOCNumber is populated in 177 of 177 Production rows (run 4: 152 of 395).	A01:2021 Broken Access Control API3:2023 Broken Object Property Level Authorization ASVS V13.2.6, V8.3.4	CWE-213, CWE-359, CWE-200	Code read (propertyMapper.js line 29 ...row) plus read-only ZCQL via the Catalyst connector (COUNT where SPOCNumber IS NOT NULL = 177).	Return an explicit field allow-list; keep contact/commercial columns out of the public table or behind an authenticated function.
S-03 Persisting	**Medium** 6.5 AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:L	Rate limiting on /api/leads and /api/lead3 keys on the client-supplied X-Forwarded-For header and uses a per-instance in-memory Map; rotating the header defeats the 10 requests/minute limit.	A04:2021 Insecure Design API4:2023 Unrestricted Resource Consumption ASVS V11.1.4	CWE-348, CWE-770	Executed: 12 requests with rotating X-Forwarded-For were never limited on /api/leads and /api/lead3 (08_api_tests.log RATE section); same-client limit works (429 on the 11th).	Take the client IP from the trusted proxy hop only; enforce limits at Catalyst API Gateway; add a CAPTCHA/Turnstile on lead forms.
S-09 New	**Medium** 6.5 AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:L	/api/list-your-property (POST creates CRM data, GET proxies city/micromarket lookups) has no rate limit, body-size check or honeypot; 15 rapid requests were never limited.	A04:2021 Insecure Design API4:2023 Unrestricted Resource Consumption ASVS V13.2.1	CWE-770	Executed: 15 requests, no 429 (08_api_tests.log RATE). Code read: no limiter in list-your-property/route.js. CRM write path not executed.	Apply the lead-route controls (limit, size cap, honeypot, CAPTCHA).
S-13 Persisting	**Medium** 5.9 AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:N	Long-lived Zoho OAuth refresh tokens are held in app environment; code defaults the Catalyst environment to Production and hard-codes the project ID and Properties table ID. The lead routes defer failures to runtime ('is missing from .env.local' errors).	A05:2021 Security Misconfiguration API8:2023 Security Misconfiguration ASVS V2.10, V6.4	CWE-1188, CWE-522	Code read: lib/catalyst.js lines 4-8, 47; lead routes. No env values were read.	Use least-privilege Zoho scopes, rotate tokens, remove hard-coded IDs, validate env at boot.
S-10 Persisting	**Medium** 5.4 AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N	Catalyst platform configuration (read-only): public sign-up is enabled although the site has no user accounts; the default App User role holds SELECT/UPDATE/INSERT on the Properties table; the Stratus bucket property-images has encryption off, versioning off, caching disabled and audit off; CORS allows 127.0.0.1, crm.zoho.in and zappsusercontent.in with iframe embedding.	A05:2021 Security Misconfiguration API8:2023 Security Misconfiguration ASVS V1.14, V4.1.3	CWE-1188, CWE-276, CWE-732	Catalyst connector, read-only: Get_Authentication_Configurations, Get_Table_Permissions, Get_All_Buckets, List_All_CORS_Domains (Production).	Disable public sign-up; make App User SELECT-only (or remove); enable bucket encryption/versioning; remove localhost from CORS in Production.
S-06 Persisting	**Medium** 5.3 AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	Internal error text, including environment-variable names, reaches API responses and users: /api/cities returns 'ZOHO_CLIENT_ID is missing'; /api/ai-search returns the JSON parser message ('Unterminated string in JSON at position 17') with HTTP 500; /api/micromarkets reports success:true when the upstream failed.	A05:2021 Security Misconfiguration API8:2023 Security Misconfiguration ASVS V7.4.1	CWE-209	Executed: curl against the local app (08_api_tests.log, ERR/AI/API sections).	Return generic messages with a request id; log details server-side only.
S-08 New	**Medium** 5.3 AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L	/api/ai-search is anonymous, has no rate limit and no prompt-size cap and calls the paid Gemini API for every request; a 20 KB prompt returns HTTP 500; malformed JSON returns 500 (not 400). The route also logs the raw user prompt and Gemini response with console.log. An attacker can exhaust the Gemini quota/billing.	A04:2021 Insecure Design API4:2023 Unrestricted Resource Consumption ASVS V11.1.4, V13.1.1	CWE-770, CWE-400, CWE-532	Executed: 15 consecutive requests from one client never returned 429; 20 KB prompt -> 500 (08_api_tests.log AI/RATE). Code read: ai-search/route.js has no limiter, console.log of prompt (lines 429-436, 789-815). Live Gemini call not exercised (no key).	Add per-IP and global limits, a prompt length cap (for example 500 characters), JSON error handling and remove prompt logging.
S-12 Persisting	**Medium** 5.3 AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	Production data is gated only by being in the table: no Published/approved status column exists in the Data Store and the public layer applies no status filter. Row drift seen in run 4 is gone this run (Data Store 177 = CRM Push_to_Website 177), but the sync mechanism that keeps them aligned is not in the repo or in deployed Catalyst Functions.	A04:2021 Insecure Design API5:2023 Broken Function Level Authorization ASVS V1.4	CWE-841	Catalyst connector: ZCQL COUNT = 177; CRM getRecordCount Push_to_Website=true = 177; code read of propertiesCache.js (no status filter); List_All_Functions shows no sync function.	Add a status column and filter; document and deploy the sync Function.

ID / status	Sev / CVSS	Finding	OWASP 2021 / API 2023 / ASVS	CWE	How verified	Recommendation
S-11 Persisting	**Medium** 4.3 AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N	Property detail metadata (title, description, Open Graph, canonical) is built from the URL slug and every /properties/{id}/{name} returns HTTP 200 (client-rendered shell), so any text can be placed in an indexable page title/description and unknown IDs are not 404. HEAD df46295 adds richer metadata but still derives it from the slug.	A03:2021 Injection (content spoofing) API8:2023 Security Misconfiguration ASVS V5.3	CWE-20, CWE-451	Executed on 1c85d7d: /properties/abc/xyz returned 200 (08_api_tests.log PG). Code read on HEAD df46295 of properties/[id]/[name]/page.js generateMetadata (all fields from the slug).	Fetch the property server-side, call notFound() when absent and build metadata from the record.
S-07 Persisting	**Medium** 4.2 AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N	No security headers: no CSP, HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy or Permissions-Policy; X-Powered-By is exposed on every response. ZAP independently reports CSP not set (183 URLs), anti-clickjacking missing (16), nosniff missing (72), X-Powered-By leak (183).	A05:2021 Security Misconfiguration API8:2023 Security Misconfiguration ASVS V14.4, V14.5	CWE-693, CWE-1021, CWE-497	Executed: header checks (08_api_tests.log HDR) and OWASP ZAP passive scan (06c_zap_baseline.log, zap_baseline.json).	Add headers() in next.config.mjs (CSP, HSTS, frame-ancestors, nosniff, Referrer-Policy, Permissions-Policy); set poweredByHeader:false.
S-14 Persisting	**Medium** 4.2 AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:N	Repository hygiene: GitHub Advanced Security is not enabled (secret scanning unavailable); .gitignore covers only .env*.local; Git history holds 8,869 node_modules/.build objects; anarock/.catalyst/slate-config.toml is tracked although .catalyst/ is ignored. Regex secret scan of the tree and 101 commits on HEAD found 0 hits.	A05:2021 Security Misconfiguration API8:2023 Security Misconfiguration ASVS V14.1	CWE-540, CWE-1188	Executed: mcp github run_secret_scanning -> 'Repository does not have GitHub Advanced Security enabled'; regex scan (05_secret_scan.log); git rev-list --objects count.	Enable secret scanning/push protection; ignore all .env*; consider history cleanup.
S-15 Persisting	**Low** 3.7 AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:L	/api/location: the 1 request/second throttle is a shared timestamp that is not serialised, the cache Map is unbounded and precise coordinates go to a third party (Nominatim) without a consent notice; malformed JSON returns 500.	A04:2021 Insecure Design API4:2023 Unrestricted Resource Consumption ASVS V8.3.1	CWE-362, CWE-400, CWE-359	Code read (location/route.js lines 7-55) and executed malformed-JSON test (500).	Serialise upstream calls, bound the cache, return 400 for bad JSON, add consent copy.
S-16 Persisting	**Low** 3.7 AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N	Catalyst Web SDK 4.6.2 loads from static.zohocdn.com on every page without Subresource Integrity, and no client code uses it.	A08:2021 Software and Data Integrity Failures API8:2023 Security Misconfiguration ASVS V14.2.3	CWE-829	Code read: layout.js lines 115-118 (no integrity attribute); grep finds no SDK use.	Remove the script or pin it with SRI.
S-17 Persisting	**Low** 3.1 AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N	Lead forms have no non-JavaScript fallback: ZAP's spider submitted a form with GET and put the email and requirement text in the URL query string.	A04:2021 Insecure Design API8:2023 Security Misconfiguration ASVS V8.3.1	CWE-598	OWASP ZAP passive scan: 'Information Disclosure - Sensitive Information in URL' (1 instance).	Set method="post" and preventDefault handlers.
S-18 Persisting	**Low** 2.3 AV:L/AC:L/PR:H/UI:N/S:U/C:L/I:N/A:N	125 console.log/error/warn statements in 28 files (HEAD df46295; 159 in 29 on 1c85d7d), including full error objects, Zoho/Gemini responses and user prompts.	A09:2021 Security Logging and Monitoring Failures API8:2023 Security Misconfiguration ASVS V7.1	CWE-532	Executed: grep count over src.	Use a structured logger with redaction and levels.

3. Scans run this run

Tool	Result	Method / evidence
npm ci + npm audit	npm ci: PASS on HEAD (363 packages). Audit (HEAD): 1 critical, 14 high, 4 moderate, 0 low (total 19)	02_npm_ci.log, 02b_npm_audit.log, npm_audit.json. Direct: next, eslint-config-next, postcss chain.
Semgrep 1.183.0 (p/owasp-top-ten, p/javascript, p/nextjs, p/react)	0 findings on 107 files (HEAD df46295)	Scanner proven on a known-bad canary (eval, innerHTML, md5, exec) -> 3 findings (06a_semgrep_canary.log). A 0-finding result means no rule-pack hits, not that the code is safe: the issues above are logic/design flaws rules do not detect.
Secret scan (regex: AWS, Google, Zoho, GitHub, Slack, private keys, key=value)	0 hits in working tree; 0 hits across 101 commits (HEAD df46295)	05_secret_scan.log. A regex scan, not gitleaks/trufflehog (not installed); lower recall.
GitHub secret scanning	Not available	GitHub tool returned 'Repository does not have GitHub Advanced Security enabled'.

Tool	Result	Method / evidence
OWASP ZAP 2.16.1 baseline (spider + passive scan; no active attack)	8 alert types: Information Disclosure - Suspicious Comments [Informational (Low)] x10; User Controllable HTML Element Attribute (Potential XSS) [Informational (Low)] x1; Content-Type Header Missing [Informational (Medium)] x2; Information Disclosure - Sensitive Information in URL [Informational (Medium)] x1; Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) [Low (Medium)] x183; X-Content-Type-Options Header Missing [Low (Medium)] x72; Content Security Policy (CSP) Header Not Set [Medium (High)] x183; Missing Anti-clickjacking Header [Medium (Medium)] x16	ZAP was downloaded and run (06b_zap_attempt.log, 06c_zap_baseline.log, zap_baseline.json) against the production build of 1c85d7d. Not repeated on HEAD because HEAD cannot be built or served.
Scripted request tests	64 pass / 43 fail of 107 on 1c85d7d (see Test Scenarios report). On HEAD the dev server returned 500 for /, /properties, /kyc/* and /list-your-property, so the suite was invalid there	08_api_tests.log (1c85d7d), 08b_api_tests_HEAD_df46295_devserver_invalid.log, 08c_head_route_status.log

4. Control coverage

Control area	Tested?	Result / reason not tested
Security headers	Yes (curl + ZAP)	All six missing; X-Powered-By exposed (S-07)
Input validation (leads, location, ai-search)	Yes	Lead validation present on /api/leads; missing/weak on lead2, ai-search, location
Rate-limit bypass	Yes	X-Forwarded-For rotation bypasses limiter (S-03); no limiter on lead2, ai-search, list-your-property
Error leakage	Yes	Env-var names and parser errors leak (S-06)
CORS	Yes	No Access-Control-Allow-Origin on API responses (pass); Catalyst-side CORS list reviewed (S-10)
Body-size limits	Yes	/api/leads 413 on Content-Length 60 KB; chunked 60 KB returns 400 not 413; lead2/ai-search have no cap
Authentication / session	N/A	The app has no user accounts; Catalyst sign-up is open (S-10)
Authorization on CRM writes (duplicate overwrite)	Code read only	Writing to production CRM is forbidden, so S-04 was not exercised
Active injection / fuzzing (ZAP active scan, sqlmap)	No	Not run: the passive baseline was chosen to stay safe; no database is reachable without credentials
SSRF via AI/Gemini and Zoho calls	Code read only	URLs are built from fixed hosts; Gemini and Zoho not reachable from the sandbox
TLS configuration / HSTS on the custom domain	Not verifiable	No Production deployment or custom domain exists yet
Function (Catalyst) source review	Not verifiable	Only stratus_upload exists and its source is neither in the repo nor retrievable via the connector

5. Limitations

- The app ran locally with no Zoho/Catalyst credentials, so production data, CRM writes, the Gemini call and external APIs (exchange rates, geocoding) could not be exercised; the sandbox proxy blocks outbound HTTPS from the Node process (SELF_SIGNED_CERT_IN_CHAIN).

- Catalyst and CRM were read through the connectors with read-only calls (list/get/ZCQL SELECT/record counts). Environment variable values and Stratus object contents were not read.

- Slate Production deployment build logs are not retrievable through the connector, so the cause of the failed Production build is not verifiable (the current code builds locally).

- No application code was modified. Scope document was read from git history because main no longer contains it (see Scope report).